Internet of Things (IoT) Policy

Effective Date:
January 21, 2026

Category:
Security

Scheduled Review:
January 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Purpose

This policy establishes requirements for the secure use, deployment, and management of Internet of Things (IoT) devices within the Commonwealth's information technology environment, ensuring alignment with state and federal cybersecurity standards.

3. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

4. Definitions

Internet of Things: Network of devices that contain the hardware, software, firmware and actuators which allow the devices to connect, interact and exchange data and information. (e.g., sensors, cameras, smart lighting, HVAC controls). IoT also includes devices such as, but not limited to, postage meters, kiosks, touchless lockers, game consoles, and barcode scanners. Devices that require connection to, or operation through, a personal computer (PC) are not considered IoT devices policy.

5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

5.1 Procurement and Approval

All IoT device procurement shall comply with the *IT Projects and Procurement Policy* and *IT Vendor Risk Management Policy.*

Devices must align with NIST SP 800-213 security guidelines and, where applicable, comply with the IoT Cybersecurity Improvement Act of 2020.

When multiple suitable IoT devices are available, preference shall be given to devices carrying the U.S. Cyber Trust Mark, which indicates testing against NIST IR 8425 in accredited laboratories. This requirement does not obligate agencies to conduct multi-vendor evaluations where none would otherwise be performed; rather, if alternatives are being considered, the Cyber Trust Mark should be used as a differentiator in the selection process.

Devices from proscribed suppliers per the *IT Procurement Intake Standard* or that communicate with nations blocked by the Geo IP Blocking Services as outlined in the *Enterprise Firewall Rule Set Standard* are prohibited.

5.2 Inventory and Asset Management

Agencies shall maintain a comprehensive and up-to-date inventory of all agency or vendor managed IoT Devices providing services to the commonwealth, including:

- Device Type
- Manufacturer & Model
- Physical Location
- Assigned Owner
- Mission-Critical Resource Y/N
- Support Contact Information (agency contact, vendor details, manufacturer escalation contacts)

Agencies must provide inventory records to OA/IT upon request.

Agencies shall be responsible for the installation, operational management, and maintenance of their IoT Devices.

5.3 Network Requirements

IoT Devices shall only be connected to approved networks as determined by the Enterprise Network and Architecture Engineering team that are physically and/or logically segmented. Devices deemed to be critical or high-risk may be required to be further segmented from other IoT Devices at the discretion of the Enterprise Information Security Office (EISO).

IoT devices that require inbound connections are exempt from the requirement to reside on the IoT Network.

IoT Devices must only have access to systems and data necessary for their function.

Unauthorized devices discovered on the network may be immediately isolated and investigated.

5.4 Security Requirements

Default usernames and passwords shall be changed before deployments and strong authentication shall be enforced.

All IoT device communications must be encrypted in accordance with the *Encryption Policy*.

Remote access must be disabled unless explicitly authorized and secured with multi-factor authentication (MFA).

Agencies shall consult their Agency or Delivery Center Information Security Office (ISO) to ensure devices adhere to industry standard best practices.

Third party vendor connections to Commonwealth resources must be reviewed by the Agency or Delivery Center ISO.

Devices must be regularly assessed and patched in accordance with the IT Resources Patching Policy.

5.5 Incident Response

Any suspected compromise of an IoT device must be reported immediately to the EISO in accordance with the *IT Security Incident Reporting Policy.*

6. Contact

Questions or comments may be directed via email to OA, IT Policy.

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy waiver shall be submitted via the enterprise IT policy waiver process. Refer to *IT Policy Governance* for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/21/2026	Base Document